macOS 原生控件保护专项验证报告

评审版 v1.0 · 2026-11-01 · 本次为新增实验，保留此前技术预研与深度报告

结论：已实现一个复用原生 AppKit 控件的保护原型，并验证部分真实编辑行为。它可以把原生控件绘制结果转成视频帧，在本机所测捕获路径中隐藏主画布，同时从原始帧录制清晰视频；尚不能让任意现有原生窗口及其全部系统交互自动获得完整防捕获能力。

评审问题	已取得的证据	判断
原生输入与按钮可否复用	NSTextField、NSTextView、NSButton、NSScrollView；基础 24 项、键盘 16 项检查通过	需要架构改造；原型可行
外部捕获能否隐藏原生主画布	同一离屏链路设置保护开关，主矩阵与键盘补测有有效对照	已验证有限路径与短时样本
中文输入过程能否完整保护	系统拼音能组合并提交；候选条被显示器、矩形及系统截图取得	当前未实现；有明确反例
隐藏原生源窗口是否安全	曾显示再隐藏后，SCK 仍取得先前原生内容	隐藏不是安全保证
自身录制是否正常	9 段 MP4 全帧解码通过；保护组源视频保留合成内容	已验证短时源帧录制

本次适用范围

环境为 Apple M4、macOS 26.6.2（25G83）、SDK 26.5、Swift 6.3.3，单台设备、单显示器、900×500 点内容区、1800×1000 像素源帧。有效主实验使用内部修订 native-controls-v0.3。未把旧版自绘画布的本机人眼确认或远程软件结果迁移为新版原生控件已验收。

按用户最新安排，已停止桌面补测，后续仅分析已保存文件并整理文档；未再切换窗口、发送键鼠事件或操作 ToDesk。本报告把失败、无效样本及待验证项目一并保留。

证据措辞：已验证＝指定设备、版本、用例中有有效输入/输出证据；未验证＝未执行或样本条件不足；推断＝依据接口与现象解释，尚无直接实验。API 调用成功、零帧、空图和 OCR 零命中均不单独作为通过标准。

01 实现：原生控件如何进入保护画面

复用控件的绘制与编辑逻辑，同时适配显示、输入和录制

离屏源窗口承载真实 NSTextField、复选框/按钮和滚动文本。通过 bitmapImageRepForCachingDisplay 与 cacheDisplay 绘制控件树及正在编辑的 field editor，再转为 BGRA CVPixelBuffer / CMSampleBuffer，送入 AVSampleBufferDisplayLayer。保护模式设置 preventsCapture=true。呈现窗口和源窗口均使用 sharingType=.readOnly，没有叠加 .none。

可见 ProxyView 接收鼠标、键盘与 NSTextInputClient 回调，换算坐标后转发给原生编辑器。选区、组合文本和已提交值来自原生控件；光标和部分键盘焦点框由代理辅助绘制，不能称为完全未经改造的原生活跃窗口。Tab 顺序也由适配器维护。

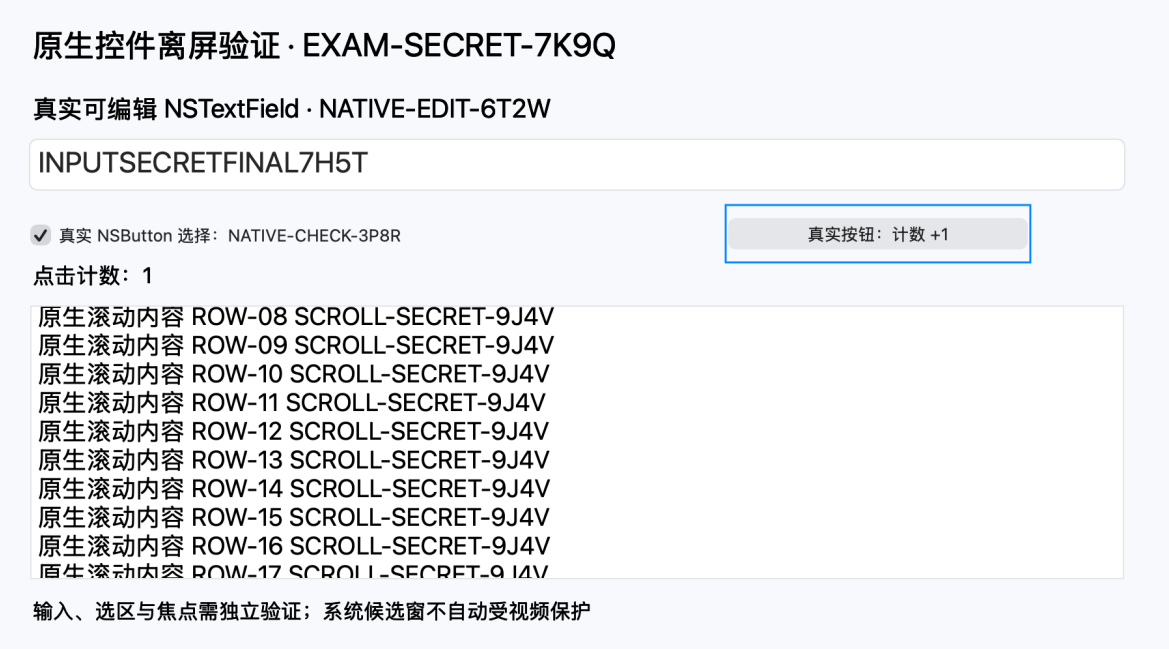


图 1 | 保护模式应用内部保存的原生源帧：实际编辑值、复选状态、按钮计数及滚动内容。它不是外部截图，也不能代替物理屏幕观察。

同一原始像素帧分两路：一路送保护显示层，另一路送 AVAssetWriter 输出 H.264 MP4。自身录制不依赖从受保护窗口重新取屏，也不使用本进程截图白名单。公共标题条和演示操作区仍是普通 UI，不纳入秘密画布。

源窗口默认位于(-10000,-10000)，从未 orderFront；此做法用于支撑离屏编辑，并非 Apple 文档化的内容安全边界。独立弹窗、菜单、候选窗以及其他窗口不会自动进入上述缓存。

02 输入与编辑：40 项状态检查

基本交互：三模式×8 项；键盘扩展：两种 raster 模式×8 项。通过数不代表设备或系统覆盖数。

基本用例	核对方式/结果	直显	无保护	保护
键盘替换输入	Cmd+A 后输入；实际值为 INPUTSECRETABC123	通过	通过	通过
左移并删除	实际值变为 INPUTSECRETABC13	通过	通过	通过
光标处插入	实际值变为 INPUTSECRETABC1Z3	通过	通过	通过
全选	selectedRange 覆盖全部 17 字符	通过	通过	通过
替换选区	实际值为 INPUTSECRETFINAL7H5T	通过	通过	通过
点击复选框	state 变为 1	通过	通过	通过
点击按钮	计数由 0 变 1	通过	通过	通过
滚轮滚动	scrollY 变为 180	通过	通过	通过

键盘扩展用例	判据	无保护	保护
双击选词	实际原生 selectedRange 非空	通过	通过
鼠标拖选	实际选择范围覆盖多个字符	通过	通过
Tab 进入复选框	逻辑焦点变为 checkbox	通过	通过
空格切换复选	复选状态翻转	通过	通过
Tab 进入按钮	逻辑焦点变为 button	通过	通过
Return 激活按钮	按钮计数增加	通过	通过
Tab 进入文本视图	逻辑焦点变为 textView	通过	通过
Shift+Tab 返回按钮	逻辑焦点变为 button	通过	通过

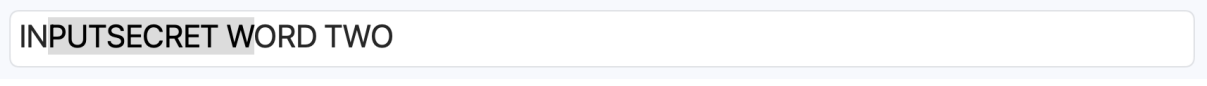


图 2｜真实拖选后的源帧局部。选区来自原生编辑器；代理辅助光标/焦点绘制已单独标识。

基础与键盘用例由独立 CGEvent 探针投递，并核对 Demo 接收后的状态及源图；不是仅调用 setText 后宣布键盘通过。英文文本的 Unicode 事件可绕过 IME，因此中文输入另用真实拼音虚拟键验证。没有完成真人长时可用性、剪贴板、撤销重做和完整读屏验收。

03 外部捕获矩阵与有效性

主批次 native-final-v03-20261101T133147Z；表中“命中/样本”指合成题目标记的 OCR 命中及实际 PNG/帧数。

路径	直显	无保护 raster	保护 raster
CG 窗口截图	1/1	1/1	0/1
CG 合成显示器截图	1/1	1/1	0/1
CG 直接显示器截图	1/1	1/1	0/1
SCK 窗口静态截图	1/1	1/1	0/1
SCK 显示器静态截图	1/1	1/1	0/1
SCK 矩形静态截图	1/1	1/1	0/1
系统 CLI 窗口截图	1/1	1/1	0/1
系统 CLI 整屏截图	1/1	1/1	无效：目标未覆盖
SCK 窗口持续流	16/16	16/16	0/16
SCK 显示器持续流	15/15	16/16	0/12
SCK 应用持续流	16/16	16/16	0 帧：无法判断

主批次保护组 36 张外部图像中，35 张有 PUBLIC-CONTROL 公共对照标记，均未检出题目、编辑标签和最终输入标记；代表截图人工复核主画布被遮挡。另一张系统整屏图未有效包含目标窗口，排除。应用流零帧也排除，不能写成保护成功。

键盘专项补测，单独计数

native-keyboard-20261101T133448Z：无保护组 38 张外部图像均检出题目/输入；保护组 39 张都有公共对照而未检出秘密标记。保护组窗口、显示器、应用流各保存 11 帧，提供主批次缺少的应用流有效样本。两批保护组共 74 张有效图像/帧；它们是短时离散观察，不能代表整个输入过程从未出现一帧泄露。

输入值、原生编辑标签与题目三类标记同时核查；PNG 数与捕获报告实际保存帧对账。全透明输出、无帧、权限错误和目标缺失分别处理。OCR 阴性不是不可读的证明；中文 OCR 尤其存在已知漏检，候选窗结论依据原图复核。按源窗口 ID 测试时产生的显示器/应用图像，不能冒充源窗口定向截图。

04 外部截图对照

相同原生离屏链路，分别关闭与开启 preventsCapture；以下都是独立捕获进程生成的窗口截图。

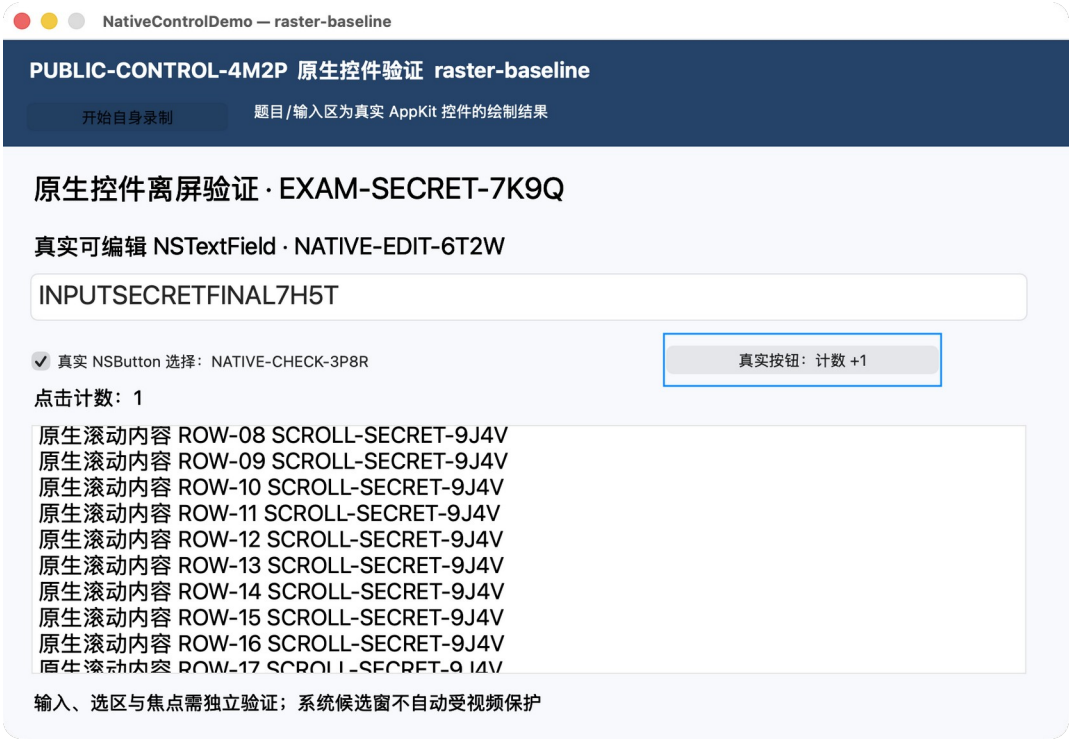


图 3 | raster-baseline：题目、真实输入框值及滚动文字均可见。



图 4 | raster-protected：公共蓝条仍可见，承载原生控件画面的区域变黑。该窗口截图不包含系统输入法的独立候选窗。

来源：主批次两个模式下 capture/sck-screenshot-window.png。保护截图中的黑色是本机观察结果，不将具体填充颜色视为跨系统保证；也不由这张图推导所有外部软件均无法获取内容。

05 中文输入：能输入，但候选条泄露

真实系统简体拼音 com.apple.inputmethod.SCIM.ITABC；不是直接向输入框写入中文。

三种模式都依次投递 n、i、h、a、o 的真实虚拟键，再按空格提交。组合时 editorText 为“ni hao”、hasMarkedText=true、范围{0,6}；提交后 currentText 为“你好”、markedText 清空。系统原有输入源在 finally 中恢复成功。

模式	真实组合/提交	组合期间外部捕获
direct	通过此单词用例	正文和候选正常可见
raster-baseline	通过此单词用例	正文和候选正常可见
raster-protected	通过此单词用例	主画布隐藏；候选文字仍可读



图 5｜保护模式的 SCK 矩形截图上半部：主画布黑色，但候选条“1 你好…3 你好吗”仍可见。仅裁去无关桌面，没有改变目标区域像素。

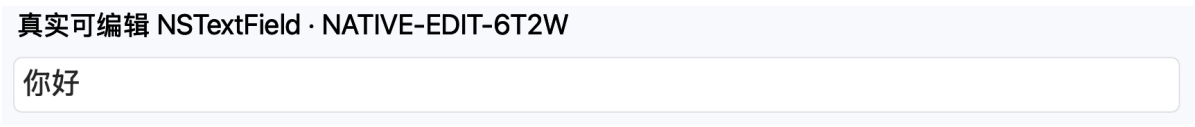


图 6｜同一保护组提交后的原生源帧局部，输入值为“你好”。它证明源绘制成功，不代表候选条被保护。

候选条在 SCK 显示器截图、SCK 矩形截图及系统 CLI 整屏截图中均可读；单抓主窗口没有带上候选条，会漏掉该反例。窗口枚举中的另一个 397×28 窗口与候选条位置吻合，但 ownerPID 仍是 Demo，不能断言候选由另一进程绘制。可确认的是它处于受保护 Layer 之外。

未覆盖候选翻页/鼠标选词、组合中删除与移动、长句、第三方输入法或真人观察。初版默认 OCR 漏检阳性对照中的“你好”；后续采用 zh-Hans 及候选区域定位，确认上述三条泄露路径。原图、状态、局部裁剪、识别坐标与 SHA 均可追溯。

06 隐藏源窗口：已取得捕获反例

独立源窗口诊断使用内部 v0.1；不能把其全部输入能力等同于 v0.3，也不能忽略此窗口生命周期反例。

源窗口阶段	CG 按源 ID 截图	SCK 按源 ID 截图	解释
从未显示	nil_image	错误-3811，无有效图	捕获失败；不是已证明安全
主动显示	有效原生明文图	有效原生明文图	阳性对照成立
显示后 orderOut 隐藏	nil_image	有效原生明文图	隐藏后仍可取到此前内容

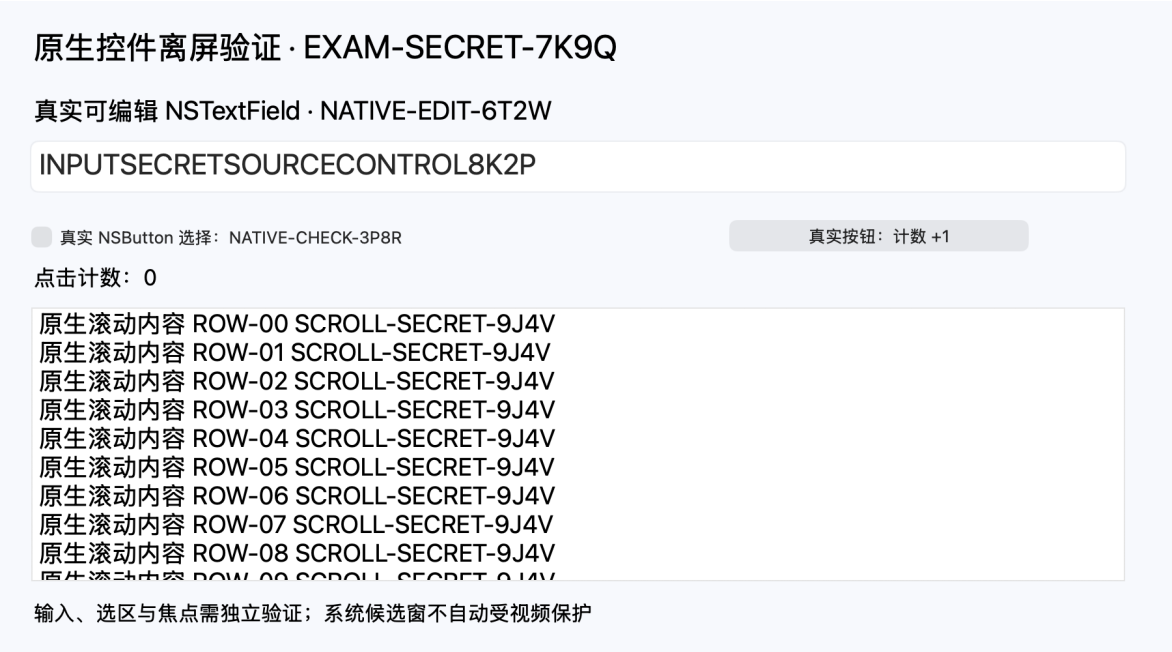


图 7｜源窗口已隐藏后，独立 SCK 按源窗口 ID 抓到的实际内容；sourceWindowVisible=false，sourceWindowEverOrderedFront=true。

三个阶段一直使用同一个 INPUTSECRETSOURCECONTROL8K2P 标记。因此本证据严格证明“先前显示过的内容可在隐藏后被取到”；没有证明隐藏后新编辑的内容也实时泄露，不能混写。未再显示源窗口的主实验虽然没有拿到源窗口定向有效图，也不构成“永远无法捕获”的保证。

生产设计必须避免源窗口意外上屏，并把显示、隐藏、恢复、窗口重建和源表面历史分别验证。仅把 NSWindow 移到屏幕外或 orderOut，不是文档化的访问控制策略。后续“隐藏后更换随机标记”的区分实验尚未执行。

源图来源：source-exposure-control-20261101T132024Z/source-hidden-after-visible-screenshot/sck-screenshot-window.png。源码快照和 run-config 记录与该历史样本对应，不用当前二进制冒充同一次测试。

07 AX 文本通道与自身录制

像素保护、辅助功能读值及原始帧录像是三种不同能力。

辅助功能（AX）观察

有效直显对照可读取 AXTextField.value=INPUTSECRETFINAL7H5T；中文提交后的直显对照可读“你好”。IME 批次两种 raster 均处于前台，公共标题可读，但本次常规 AX 树遍历没有返回题目/输入文本。无保护 raster 也如此，故不能把差异归因于 preventsCapture。

主矩阵保护组 AX 时失去前台且公共标题也未命中，不能作为有效完整阴性；键盘专项未测 AX。遍历无截断也不等于穷尽参数化属性、焦点入口、延迟变化或候选窗。当前代理未完成原生控件语义的无障碍映射，不能称完整读屏支持。

9 段视频完整性检查

批次/模式	时长（秒）	解码帧数	检查
主矩阵 / direct	19.590	456	通过
主矩阵 / baseline	22.327	584	通过
主矩阵 / protected	23.078	600	通过
键盘 / baseline	13.988	326	通过
键盘 / protected	14.237	333	通过
IME / direct	8.010	172	通过
IME / baseline	8.213	188	通过
IME / protected	8.340	192	通过
源窗口诊断 / v0.1	5.652	129	通过

全部为 1800×1000、H.264，共 2,980 帧。ffmpeg 全帧解码返回 0，无解码错误；逐帧 PTS 检查无倒退或重复。每段另提取开始/中间/结束 3 张代表帧，共 27 张，核对内容。完整解码不等于逐帧内容/文字正确性验收，也不证明屏幕上已显示同一帧。

视频位于各批次模式目录的 self-recording-*.mp4；精确文件名、SHA、时长、PTS 与解码结果见 research/video-integrity.json。录制的是保护前的源画布，不含系统候选窗、系统标题栏或普通公共外壳。

08 性能、版本和部署边界

这是单机工程原型；API 的最低版本与本 Demo 实际构建目标、实测系统要分开。

项目	当前结果/限制
源绘制性能	主矩阵保护组平均 15.18ms、P95 19.41ms；键盘保护组平均 16.39ms、P95 21.03ms。为应用内 render 采样，非端到端输入显示延迟。
帧率和清晰度	目标定时器 20fps，输入/命令也触发绘制，所以并非恒定 20fps；2×位图保留 Retina 文字细节。没有跨缩放/外接屏/动态改尺寸测量。
内存、CPU、长时稳定性	未做系统资源基准、温升、数小时录像和内存泄漏测试；0 次 writer 丢帧仅限这些短段。
preventsCapture	macOS 10.15 起；公开 AVFoundation 属性，所核验声明无专用 entitlement。保护对象是该 Layer 内容。
AppKit 绘制和文本输入	cacheDisplay、field editor 和 NSTextInputClient 为公开 API。部分历史 AppKit 接口未从本轮资料确定精确引入版本，不编造最低值。
Demo 构建/实测	脚本编译 arm64、最低部署目标 13.0；本轮仅在 26.6.2 实测。bundle 版本字段仍为 0.1，内部代码修订 v0.3，以 SHA 识别产物。
捕获探针版本	SCK 流 12.3 起，filter 截图 14.0 起，矩形截图 15.2 起；调用有 availability 分支。CG 截图为已废止兼容路径，另用旧部署目标 C shim 测试。
权限与签名	Demo 本身显示/源帧录制无需屏幕录制 TCC；独立跨应用捕获需相应授权。输入/AX 用本机既有授权，未改 TCC。构建为 ad-hoc 签名，未做公证、商店或沙箱验收。

本轮未使用 FairPlay、HDCP 配置、系统扩展、Endpoint Security、DriverKit、Kext 或私有 WindowServer 接口，也没有建立“只有自身进程可取屏”的系统白名单。此前关于其他路线的研究仍在旧报告中保留，本报告不重做或升级它们的验证等级。

API 版本与语义依据：原工程 docs/API 依据.md、本次 research/native-api-evidence.md，以及 Apple 官方链接。CG 运行时兼容观察不等于当前 SDK 正式支持该 API，也不是新产品应依赖的持续支持承诺。

09 证据目录、无效样本与复现

目录均相对于新项目“原生控件验证_20261101”；旧报告和旧实验保留。

目录/文件	用途与采信范围
artifacts/native-final-v03-20261101T133147Z	主实验：direct、baseline、protected 各 8 项；mixed 失去前台后仅 3/8，不作为完整通过。
artifacts/native-keyboard-20261101T133448Z	键盘专项：两种 raster 各 8 项；有效应用流补测。
artifacts/native-ime-20261101T134127Z	真实系统拼音：组合/提交状态、三类截图及候选窗反例。
artifacts/source-exposure-control-20261101T132024Z	v0.1 源窗口三阶段对照；隐藏后仍有可读旧内容。
research/video-integrity.json；ax-audit.json	全帧视频解码、PTS、代表帧；14 次 AX 历史及新增审阅。
research/report-figure-provenance.json	本报告配图原始路径、SHA、裁剪矩形；配图不是新增实验。
docs/构建与复现.md；README.md	源码、构建、模式、人工复现及自动测试说明。

保留的问题与无效实验

v0.1 曾发生探针 SCShareableContent 异步桥接崩溃：回调 content 与 error 均为 nil。已改为显式检查并记录错误；系统为何返回双 nil 尚不清楚。此前崩溃不算保护成功。v0.2 早期样本有 Edit 菜单/前台问题；v0.3 主矩阵 mixed 失去活动/key 状态，后续输入被探针拒绝。具体触发原因未定位，不能归咎于 ToDesk 或另一操作者。

早期 v0.2 mixed 仍有独立反例：普通原生叠加标签 NATIVE-LEAK-8R3T 在 49 张外部图像均可读，而保护画布秘密标记未检出。此观察可支持“普通 overlay 不继承保护”，但该批次直显/基线不完整，不纳入主矩阵通过数。

未来复现顺序

先阅读 README，构建 Demo 与探针；在桌面空闲、授权就绪时依次运行 direct、raster-baseline、raster-protected，记录实际窗口 ID、PID、源码/二进制 SHA，再执行基础、键盘、IME 与捕获脚本。每轮用新目录，禁止覆盖证据。当前未再次运行这些桌面步骤。

主实验源码 SHA：b256ce232aeba98257de5b87d6061f516fe910eb6c5bfd91eac1b2fd9cf72c77；二进制 SHA：0cbe3e4fafc0cc30b2877940f7c4f814815d2e2748365a5e571f79020a6b4aa1。各 run-config.json 另记录捕获探针 SHA 和实际启动参数。

10 下一阶段验收与官方依据

不能把本轮有限成功扩展成产品级完整防截屏承诺。

待验证/待改造	通过所需证据
本机实际观看与远端接收画面	新版原生 Demo 真人检查，UU/ToDesk 接收端录制与主机同步时间/内容；仅软件正在运行不算测试。
中文候选与其他辅助窗	解决已发现的候选泄露，再测真实组合、选词、取消；覆盖菜单、右键、tooltip、弹窗、文件选择等。
源窗口生命周期	隐藏后换新随机标记，区分旧缓存与新内容；显示/隐藏/恢复/重建与异常路径均做定向捕获。
连续过程/瞬态泄露	边输入边窗口/显示器录制，最小化、恢复、隐藏、显示全过程；已写连续脚本但本轮未执行。
完整交互与辅助功能	中文长句、输入法多分支、多行编辑、剪贴板、撤销重做、VoiceOver 与键盘全访问。
兼容与性能	最低部署版本、其他 macOS、Intel、外接显示器/缩放、窗口调整、多小时录像与资源测量。

Apple 官方文档（设计依据，不替代实验）

AVSampleBufferDisplayLayer.preventsCapture：视频 Layer 的捕获保护

NSView.cacheDisplay(in:to:)：将视图绘制到位图

Text Fields, Text Views, and the Field Editor：原生输入框编辑模型

NSTextInputClient：系统文本输入协议

NSWindow.orderOut(_:)：隐藏窗口；不是捕获访问控制

SCShareableContent：可共享内容枚举

AXUIElementCopyAttributeValue：辅助功能属性读取

最终分级：特定原生控件主画布＝需要架构改造，已有可运行原型与有限验证；任意现有原生窗口及全部系统辅助 UI 完整保护＝当前未实现；当前已发现的中文候选泄露使完整目标不能判为通过。